AUTHZEN AND STANDARDIZED AUTHORIZATION DECISIONS

The emerging AuthZen standard defines a common API for making authorization decisions. Rather than create a new policy model or language, AuthZen concentrates on standardizing the requests and responses between a policy enforcement point (PEP) and a policy decision point (PDP).

In this chapter, ACME's gateways, sidecars, and service proxies transform requests into Cedar's PARC format before requesting a decision. AuthZen serves a similar purpose: It defines how a PEP asks, "May this principal perform this action on this resource in this context?" and how the PDP responds.

Architecturally, AuthZen could sit in front of Cedar, enabling ACME to swap or combine policy engines without altering enforcement points. In practice, many systems today use engine-specific formats like PARC. AuthZen's value lies in promoting interoperability and reducing coupling between enforcement infrastructure and decision engines.

11.2 Authorization for external access to APIs

As the web became more interconnected, people increasingly wanted to link services together. A classic example was allowing a photo-printing site to fetch your pictures from an online photo service. In the beginning, the only way to do that was to give the printing site your username and password for the photo service. That *password anti-pattern* had obvious problems: the printing site could impersonate you, it had full access to your account instead of just the data it needed, and you had no way to revoke access without changing your password everywhere.

OAuth (https://oauth.net/2/) was developed to address this problem. Instead of sharing authentication factors like passwords, people can grant an application limited access to their data by approving specific scopes. These scopes specify what the application is allowed to do, such as reading contacts but not sending emails, and they can be revoked at any time without